remains the same: intercept the request, enrich it with context, evaluate it against policy, and enforce the result.

With that foundation in place, we're ready to explore how systems define who gets access to what. In the next chapter, we will examine the most common authorization models—from access control lists to roles to attributes—and how each one influences the design, enforcement, and understanding of policies.

4.7 Summary

- Authorization defines what an authenticated principal can do, under which conditions, and with what resources. This discipline is separate from authentication and plays a crucial role in security, compliance, and user experience.
- Authorization not only protects resources but also governs interactions between entities based on the terms of their digital relationships.
- The PARC model—*p*rincipal, *a*ction, *r*esource, and *c*onditions—offers a clear and flexible framework for describing access decisions.
- Terms like policy, role, attribute, and entitlement form the foundation of modern authorization systems and foster a shared understanding across teams.
- The authorization reference architecture delineates the responsibilities of enforcement, decision-making, policy management, and context retrieval, thereby enhancing system maintainability, auditability, and security.
- Deployment patterns vary depending on system architecture; PEPs, PDPs, and entity caches can be embedded, centralized, or distributed based on performance, trust boundaries, and operational requirements.
- Separating concerns among PEPs, PDPs, PAPs, and PIPs allows systems to scale, maintain consistency, and respond flexibly to evolving business and regulatory needs.